TP3 Aspects

CSE 360 HW3 - Task 3.1 - Lessons Learned System (TP3)

These are the top five new operational aspects the team needs to finish the project. Each one supports the staff roles (contributor, viewer, curator and admin) described in the Lessons Learned System Initial User Stories V1, and each is tied to a weakness from the team's Top Defects list. Every team member is responsible for at least one aspect.

Aspects and Responsible Team Members

#	Aspect	What it means for the staff roles	Related user stories and epics	Team member
1	**Staff input is validated (CWE-20 Improper Input Validation)**	Everything staff roles type or send is checked before it is used or saved: search terms, curator edits and notes, time and effort data being merged, keyword searches, and prompts sent to the AI tools. Bad input gets a clear error message and is never saved.	Curator epics: AI search terms, AI edit and refine, merge time and effort data. Viewer: keyword search. Contributor Phase 3 AI epic.	Elijah
2	**Staff actions have limits (CWE-770 Allocation of Resources Without Limits)**	Staff features that can grow without bound are capped so the system stays usable: number of AI requests, size of search results and lesson lists, number of lessons merged at once, and length of text entered.	Curator epics: AI search terms, AI edit and refine, merge time and effort data. Viewer: list all lessons, keyword search. Contributor Phase 3 AI epic.	Ronald
3	**Each role reaches only its own functions (A01 Broken Access Control)**	Contributors, viewers, curators and admins each see and use only what their role allows. Contributors never see curator-only information or other contributors' submissions, and viewers can read but not change lessons.	Contributor Phase 2 stories on seeing only own content. Viewer stories. Curator epics. Roles in the Foundations code.	Hung
4	**Permissions are enforced the same way everywhere (CWE-284 Improper Access Control)**	Locks and visibility rules are enforced in the system's logic, not only on screen. When a curator locks a lesson or field, the contributor cannot edit or delete it. A curator's choice to show or hide time and effort statistics is respected on every screen.	Curator epics: lock lessons or fields, make time and effort data visible or not to the contributor. Contributor stories on locked fields.	Hung
5	**Staff log in securely and play the right role (A07 Authentication Failures)**	Staff roles must be authenticated before any staff function is used. This covers invitations with one-time codes and deadlines, one-time passwords, choosing a role after login when a user has several, logging out, and creating the new roles in the same pattern as the Foundations roles.	New Users, Admin (Foundations and Phase One) stories on login, roles, invitations and one-time passwords.	Rohan

Team: Elijah, Ronald, Hung, Rohan